

INFORMATION SECURITY (IS)

Information: Processed, structured data with meaning and value

Information security: Protection of the CIA of information

IS Importance: minimize downtime, protect processed/stored information, safe operation of applications, safeguarding assets from theft/misuse

Non-repudiation: Prevents parties from denying their actions

Accountability: Ability to trace actions back to a person

Authentication: Verifies the identity of a user or system

Authorization: Determines actions an entity is allowed to do

Access control: Restrict access to resources based on rules

Security policy: A rule/expectation for protecting information

Compliance: Adherence to laws, regulations, and standards

Information types: Personal, business, financial, intellectual, system

Components of an Information System (IS): Software, Hardware, Data, People, Procedures, Networks

Bottom-Up: Implementations happen before policies

Top-Down: Initiated by management, more effective

McComber cube: x: CIA (what), y: IS (where), z: Ctrl (how)

(C)onfidentiality: Prevent unauthorized access to info

(I)ntegrity: Protect reliability and correctness of information

(A)vailability: Ensure uninterrupted access to information

Information states: In storage, in transit, in use

Control: A measure designed to reduce the potential risk of an attack by eg. Policy, Education, Technology

(S)poofing: Pretending to be someone else

(T)ampering: Unauthorized data modification or altering

(R)epudiation: Denying actions without proof

(I)nformation disclosure: Exposing sensitive information

(D)enial of service: Making systems or services unavailable

(E)levation of privilege: Gaining unauthorized rights

Intellectual property: Legal rights protecting creations of the mind: Copyright, (Registered) Trademarks, Patents, Trade Secrets

Trademark: Protects brand identifiers such as names, logos, or symbols

Patent: Protects inventions and technological solutions

THREAT CATEGORIZATION

SOCIAL ENGINEERING

Manipulating people to reveal confidential information

Phishing: Forged emails impersonating legitimate entities

Spear Phishing: Targeted phishing to specific individuals

Vishing: Voice-based phishing over phone or video calls

Smishing: SMS / Text-based phishing

SOFTWARE ATTACKS

Exploiting vulnerabilities in software to gain access/steal data

Viruses: Malware that attaches to programs and spreads

Worms: Self-replicating malware that spreads over a network

Trojan Horse: Malicious SW disguised as legitimate apps

Rootkit: Encrypted victim data, asks payment to restore

Rootkits: SW hides malicious acts, maintains priv. access

DENIAL OF SERVICE

Overloading one or multiple systems to make it unavailable

DoS: Single source denial of service attacks

DDoS: DoS performed by multiple attackers/devices

Botnet: Network of compromised devices controlled by an attacker and used to together to flood a target with traffic

SYN-Flood Attack: Sending many TCP connection requests without completing them

Reflection Attack: Attacker spoofs victim's IP, sends requests to a service so that it sends (many) replies to victim

WEB APPLICATION ATTACKS

Exploiting vulnerabilities in websites/servers hosting websites

SQL Injection: Insert malicious SQL commands into an input

Cross-Site Scripting (XSS): Inject malicious scripts into website that execute in users' browsers to steal data. Relies on reflected input. Often uses <script>. Defense: limit amount of user input chars

Cross-Site Request Forgery (CSRF): Trick logged-in user's browser into sending reqs to a webapp on attacker's behalf

Broken Authentication: Weak auth mechanisms allow attackers to gain unauthorized access (password/session)

PASSWORD / AUTHENTICATION ATTACKS

Compromising login systems to gain unauthorized access

Rainbow Table Attacks: Precomputed hash lookup tables to reverse weakly hashed passwords back into plaintext

Password Spraying: Trying a few common passwords like "password" across many accounts to avoid lock-timeouts

Credential Stuffing: Using leaked credentials from previous breaches to attempt logins on other services

Brute Force Attack: Repeatedly try many username & password combinations until they gain access to an account

Bypass technical controls by accessing physical infrastructure

Theft of devices: Physically steal hardware to gain direct access to stored data, credential, internal systems, ...

Hardware tampering: Modify/implant malicious components in to intercept data, bypass security, or disrupt operations

Power disruption: Interrupt or manipulate power supply impacting availability and business continuity

Environmental damage: Environmental events that damage infrastructure, causing data loss, downtime, ...

INFORMATION SECURITY MANAGEMENT (ISM)

Information security governance: System by which IS strategy is controlled to ensure that it supports business objectives, manages risk appropriately, and complies with legal and other regulatory requirements. (what)

Information Security Management System (ISMS): Framework used to manage and protect assets through policies, processes and controls (how)

Enterprise Information Security Policy (EISP): High-level Information security policy that sets the strategic direction and scope for all an organization's security efforts

Statement of Purpose: Scope, objectives, and purpose

Info Security Elements: Core principles & concepts (CIA)

Need for IS: IS importance & legal/ethical responsibility

IS Responsibilities and Roles: Organizational structure

Security Awareness and Training: Educational programs to ensure employees know their security responsibilities

Monitoring, Measurement and Audits: Ongoing evaluation of control effectiveness and ISMS performance

Issue-specific security policy: Detailed, targeted guidance to instruct people in the use of a specific resource

POLICY

Practices: Ex. actions that illustrate compliance with policies

Policy: Instructions that dictate certain behavior within an org

Standard: Details of what must be done to comply with policy

Guidelines: Non-mandatory recommendations (reference)

Procedures: Step-by-step instructions to assist employees

De jure standard: Formally evaluated and approved by org

De facto standard: Widely adopted/accepted by public group

What does a policy do?: Establishes authority, account, responsibility, Foundation for standards, procedures, guidelines

Who is responsible for policies?: Created by senior mgmt. Enforced by mgmt. Employees responsible for compliance

How is it enforced?: Communicate, integrate into standards, monitor compliance, disciplinary measure on violation

Cyber Resilience Act (EU): Requires secure-by-design digital products and vulnerability management

DESIGNING EFFECTIVE POLICIES

- Development: Must align with organizational goals, business risks and legal requirements
- Distribution: to all affected entities in a timely manner
- Comprehension: Readable for, available to and read by all
- Compliance: Formally agreed to by act or affirmation
- Enforcement: Uniformly applied to all affected entities
- Review: Reviewed regularly in a changing environment

RISK ANALYSIS

Identify Assets → Identify Threats → Identify Vulnerabilities → Assess Likelihood → Assess Impact → Determine Risk Level

Asset: Item of value belonging to an organization. eg: Information: Customer data, intellectual property, code

Technical: Services, applications, databases, networks

Physical: Servers, devices, facilities, infrastructure

Human: Employees, administrators, contractors

Business Process: Critical operational workflows

Threat: An event or action with the potential to cause harm by exploiting a vulnerability. eg: power outage, vishing

CLASSIFYING ASSETS

Public: Information that can be shared without risk

Internal: Information for organization internal use only

Confidential: Sensitive info, could cause harm if disclosed

Restricted: Highly sensitive, strictly limited, strongly protected

SECURITY CONTROLS

Administrative/Management Controls: Policies, procedures, security training, security governance

Technical / Logical Controls: Firewalls, encryption, access control systems, system hardening

Physical Controls: Physical locks, surveillance cameras, secure access badges, turnstiles

Preventive Controls: Stop incidents before they occur. eg. Firewalls, access control, encryption

Detective Controls: Identify incidents when they occur. eg. Intrusion detection, log monitoring, SIEM, CCTV

Corrective Controls: Limit damage, restore systems after an incident. eg. Backups, system restore, incident response

Deterrent Controls: Discourage malicious behavior. eg. Warning banners, monitoring notices, disciplinary policies

Compensating Controls: Reduce risk when a primary control cannot be implemented. eg. Network isolation, layered security, alternative safeguards

Business continuity: Ensures critical operations continue during disruptions. Objectives: maintain operations, minimize impact, protect assets, recover fast

SECURITY AND AWARENESS TRAINING

- Awareness: basic information, what
- Training: detailed knowledge, how
- Education: depth of knowledge, why

GAP ANALYSIS

Define target framework → Assess curr state → Identify gaps, assess risk → Eval, prioritize gaps → Create remediation plan

SECURITY FRAMEWORK

NIST Cybersecurity Framework: Framework for managing cyber risk: Identify, Protect, Detect, Respond, Recover. ISO 27000 is a certifiable international standard, where the NIST does not have certification.

CIS Controls: Defines 18 practical technical security controls

THREATS

Attack: Act that intends to damage, steal or degrade assets

Vulnerability: A weakness in a system that can be abused

Exploit: A method used to take advantage of a vulnerability

Risk: The likelihood of a threat exploiting a vulnerability and the potential harm that could cause = Vulnerability + Threat

Threat vector: Path, method, or delivery mechanism that a threat uses to reach an asset and exploit a vulnerability

Attack surface: ∑ of threat vectors hackers can use to attack

RISK MANAGEMENT (RM)

The process of identifying, assessing, prioritizing and mitigating threats to an asset from an organisation

Risk management process: Implementation, analysis, evaluation of the risk management framework (doing)

Risk assessment: Identification, analysis, and evaluation of risk as initial parts of risk management

Risk treatment & Risk Owner: Application of safeguards or controls to reduce the risks to an acceptable level

- Risk identification: Where and what is the risk?
- Risk analysis: How severe is the current level of risk?
- Risk evaluation: Is the current level of risk acceptable?
- Risk treatment: How do I bring risk to acceptable level?

Risk management framework: Structure of the strategic planning and design of risk management efforts (planning)

- Exec Governance & Support: Support by mgmt & usrs
- FW Design: Define methods, risk appetite strategy
- Framework Implementation: Rollout of the plan
- Monitoring & Review: How effective is entire system?
- Continuous Improvement: Adaption to new threats

Risk appetite (strategic): The quantity of risk that organizations are willing to accept, to achieve their goals

Risk tolerance (specific): The acceptable risk organizations are willing to accept for a specific asset

Residual risk: Remaining risk after controls were applied

Common Vulnerabilities and Exposures (CVE): Standard identification number for vulnerabilities

Common Vulnerability Scoring System (CVSS): Severity scores for vulnerabilities based on CIA (14d to be remediated)

QUANTITATIVE RISK ANALYSIS

- Assign Asset Value (AV)
  - Identify the organization's information assets.
  - Classify them.
  - Categorize them into useful groups.
  - Prioritize them by overall importance.
- Calculate Exposure Factor (EF = Damage/AV) percentage of loss that an organization would experience if a specific asset is isolated by a realized risk
- Calculate single loss expectancy (SLE = AV × EF) Exact amount of loss if an asset were harmed by a threat
- Assess the annualized rate of occurrence (ARO) Expected occurrence frequency of a threat within a year
- Derive the annualized loss expectancy (ALE=SLE × ARO) possible yearly cost of all instances of a realized threat against an asset
- Perform cost/benefit analysis of countermeasures

Safeguard: Reduce the ARO and/or reduce the SLE

Annual cost of a safeguard (ACS): \$ / year

ALE with safeguards (ALE2): ALE with updated ARO/SLE

Value of a safeguard: ALE1 - ALE2 - ACS. Negative = bad (you shouldn't spend more on a safeguard than the value of the asset itself)

Risk Evaluation: Compare risk with risk appetite of the org

Important Indicators (Business Impact): Maximum Tolerable Downtime (MTD) Recovery Point Objective (RPO) Recovery Time Objective (RTO) Work Recovery Time (WRT)

Risk treatment:

Mitigation: Apply safeguards to eliminate remaining risk (Firewall, Training)

Transfer: Shift risks to other areas/entities (Outsourcing)

Acceptance: Leave assets vulnerability facing the current risk level (after formal evaluation)

Termination: Remove asset from the environment

Risk mitigation:

- Fix vulnerabilities
- Applying controls (tools, processes, rules to mitigate risk)
- Reduce final impact (if vulnerabilities happen)

Endpoint Detection and Response (EDR): Software watching for sus behaviour, responds with measures

Extended Detection and Response (XDR): Like EDR but watching everywhere (not just on endpoints)

IDENTITY & ACCESS MANAGEMENT (IAM)

Provisioning and protecting digital ids & access permissions

Subject: Active entity that accesses a passive object. users, programs, processes, services, computers

Object: Passive entity that provides information to subjects. files, data-bases, computers, programs, services, printers

Physical controls: To prevent, monitor, or detect direct contact with systems: guards, fences, motion detectors

Technical or logical controls: To manage access and provide protection for resources. Auth, encryption, ACL

Administrative controls: Policies and procedures. hiring practices, background checks, security training

Identification: Claiming an identity, eg. typing a username

Authentication: Verifying validity of claimed id, eg. password

- Something you know, eg. password
- Something you have, eg. smartcard
- Something you are/something you do, eg. biometrics
- Somewhere you are/s aren't (secondary factor)

Multifactor Auth: Using two or more factors

Synchronous Dynamic Password Tokens: Generate time-based passwords that are synced with an auth server (TOTP)

Asynchronous Dynamic Password Tokens: Generate passwords based on algorithm and incr. counter, remain valid until used (HOTP)

Biometric access:

False Reject Rate (FRR): Authorized users who are denied access

False Accept Rate (FAR): Unauthorized users who are granted access

Crossover Error Rate (CER): Point where FRR == FAR

- Basic Authentication: Username/pw transmitted in the clear
- One Time Passwords: Basic auth but used only once
- Challenge / Response: Password and one-time challenge
- Anonymous Key Exchange: Exchange credentials over unauthenticated secure channel, eg. diffie-hellmann
- Zero-Knowledge Password Protocols: Does not permit offline-based password attacks
- Server Certificates + User Authentication: Transmit user password over unilaterally authenticated secure channel
- Mutual Public Key Authentication: Bilateral use of public key signatures

| Attack                              | 1 | 2 | 3 | 4 | 5 | 6 | 7 |
|-------------------------------------|---|---|---|---|---|---|---|
| Passive Password Sniffing           | x |   |   |   |   |   |   |
| Offline Brute Force Password Attack | x | x | x | x |   |   |   |
| Active Man-in-the-Middle Attack     | x | x | x | x |   |   |   |
| Identity Theft on Server            | x | x | x | x | x | x |   |
| CA Compromise                       |   |   |   |   | x | x |   |

KERBEROS

Client encrypts timestamp inside the authenticator, sends it to KDC. If KDC verifies that the time is within a specified amount (def=5min), then OK. Tickets issued by KDC also have expiration time. Uses symmetric key encryption (DES). KDC stores a list of hashes of the principals' passwords. Because hash is used as the symmetric key (Master Key), an attacker with the hash can impersonate user without needing plaintext password. Password itself never traverses the network.

Principal: A Kerberos participant

Principal's Master Key: Long-term secret between the principal and KDC. Used to en-/decrypt authentication tickets.

Kerberos Ticket: Temporary credential for network services

Authentication Server (AS): Verifies client, gives TGT

Ticket Granting Server (TGS): Grants services, gives ST

Ticket Granting Ticket (TGT): Given by the AS

Service Ticket (ST): Given by the TGS

Key Distribution Center (KDC): Verifies & manages auth credentials, distributes session keys to users and services

RADIUS

Remote Authentication Dial-In User Service provides centralized authentication, Authorization and Accounting (AAA)

- User requests access from Network Access Server (NAS)
- NAS prompts the RADIUS server for credentials
  - RADIUS server evaluates the request and returns one of:
    - Access-Accept: User authenticated, NAS grants access
    - Access-Reject: Invalid credentials, NAS denies access
    - Access-Challenge: Server requires more info (MFA)
- Connected: NAS sends Accounting-Request (log session)

| Attack                              | Kerberos | RADIUS |
|-------------------------------------|----------|--------|
| Passive Password Sniffing           |          |        |
| Offline Brute Force Password Attack | x        | x      |
| Active Man-in-the-Middle Attack     |          | x      |
| Identity Theft on Server            |          |        |
| CA Compromise                       |          | x      |

AUTHORIZATION

Access Control — Discretionary — Mandatory

Provisioning and protecting digital ids & access permissions

Nondiscretionary — Lattice-based — Role-/Task-based

Discretionary access control (DAC): Every object has an owner, the owner can grant or deny access (sharing drive)

Nondiscretionary access control (NDAC): Access controls that are implemented by a central authority (HIPAA/DSG)

Lattice-based access control (LBAC): Assigns users a matrix of authorizations for particular areas

Mandatory access control (MAC): Labels applied to both subjects and objects (classified documents ↔ glows)

Role-based access control (RBAC): Privileges are tied to a role or job (project info ↔ project manager)

Task-based (TBAC) access control: Privileges are tied to a task (access to server room ↔ technician's time slot)

Auditing: A subject's actions are tracked and recorded

Accounting: Consumption of resources by a subject is measured, metered, and collected.

Salting: Adds unique random value password before hashing, prevents same passwords from producing same hash

Access Aggregation Attacks (passive): Aggregate nonsensitive info to learn sensitive info (Reconnaissance attack)

Password Attacks (brute-force): Online (accounts) vs Offline (steal account database and crack the passwords)

Dictionary Attack (brute-force): Discover passwords by using every possible password in a predefined database

Birthday Attack (brute-force): Finding collisions. MD5 is not collision free, SHA-3 is safe against collisions

Sniffer Attacks: Application that captures traffic traveling over the network. Encrypt all sensitive data, Use OTP.

CRYPTOGRAPHY

Objectives: Confidentiality, Integrity, Auth, Non-repudiation

Steganography: Embedding secret messages within content

Nonce: Unique number for each usage. Makes sure that key is not reused. Nonce is public, (shared) key is private

One-Way Functions: Easily produces output values but makes it impossible to retrieve the input values

Reversability: Being able to undo the operation of encryption

Ciphertext/Cryptogram: Encrypted message

Cipher: Encryption algorithm. Set of rules for en-/decrypting Key/Cryptovariable: Usually a very large binary number

Key space: Range of numbers from 0 to 2<sup>n</sup>, where n is the bit size of the key. A 128-bit key is in [0, ..., 2<sup>128</sup>]

Initialization vector (IV): Random bit string, same length as the block size and is XORed with the message to create unique ciphertext every time same message is encrypted

Kerckhoff's Principle: Security stems from the secrecy of the key and not the secrecy of the algorithm

Shannon's Principles:

- Confusion: Relationship between the plaintext and the key is complicated. S-Box, substitution
- Diffusion: Change in plaintext results in multiple changes spread throughout the ciphertext. P-Box, permutation

SP-Network: Repeated substitution and permutation

One-Time-Pad (OTP): XORing all bytes with one-time block of same size. Technically unbreakable

Hashing: Maps data to fixed-size output. Should be: random, diffused, fast, deterministic, irreversible, collisionless

Password storage: Prefer slow hash functions (PBKDF2, bcrypt, argon2)

Summarizing data: Prefer fast hash functions (MD5, SHA-1/2/3)

Data integrity (symmetric enc): Encrypt msg, then hash w/ shared key

HMAC: Hash based MAC, splits a key in two and hashes twice, not vulnerable to length extension attack

SHA-1: Insecure, fast

SHA-2: 256/512-bit variants secure (lower = insecure), current standard

SHA-3: (KECCAK), flexible, = as secure as SHA-2

KMAC 128/256: SHA-3 based KECCAK MAC

bcrypt: Salted, GPU-resistant

Argon2: Highly secure, configurable

AES: Advanced Encryption Standard (SP-Net). XOR, SubBytes, ShiftRows, MixColumns, repeat (128 bit block size)

Ephemeral public keys: Used for communication

Long-term public keys: Used for authentication

SYMMETRIC CRYPTOGRAPHY

Relies on shared secret key, distributed to all members before communication. No non-repudiation or message integrity.

Stream ciphers: Approximate OTP by generating infinite random keystream, work on messages of any length, nonce guarantees uniqueness, fast, no guaranteed integrity

Block ciphers: Take input of fixed size and return output of same size, use confusion and diffusion (SP-Network) AES

Electronic Code Book (ECB): Encrypt blocks sequentially with same key. Weak to redundant data divulging patterns

Cipher Block Chaining (CBC): XOR the IV with first input, then XOR output with next input. Not parallelizable

Counter Mode (CTR): Encrypt counter to produce stream cipher and XOR it with message. Parallelizable. AES

ASYMMETRIC CRYPTOGRAPHY

Relies on mathematically linked key pairs. n ∈ N \ {0}, z ∈ Z

- Encrypting a message so only one specific recipient can read it. → Recipient's public key
- Decrypting a message that was sent to me. → My own private key
- Producing a digital signature on a message. → Signer's private key
- Verifying a digital signature. → Signer's public key

